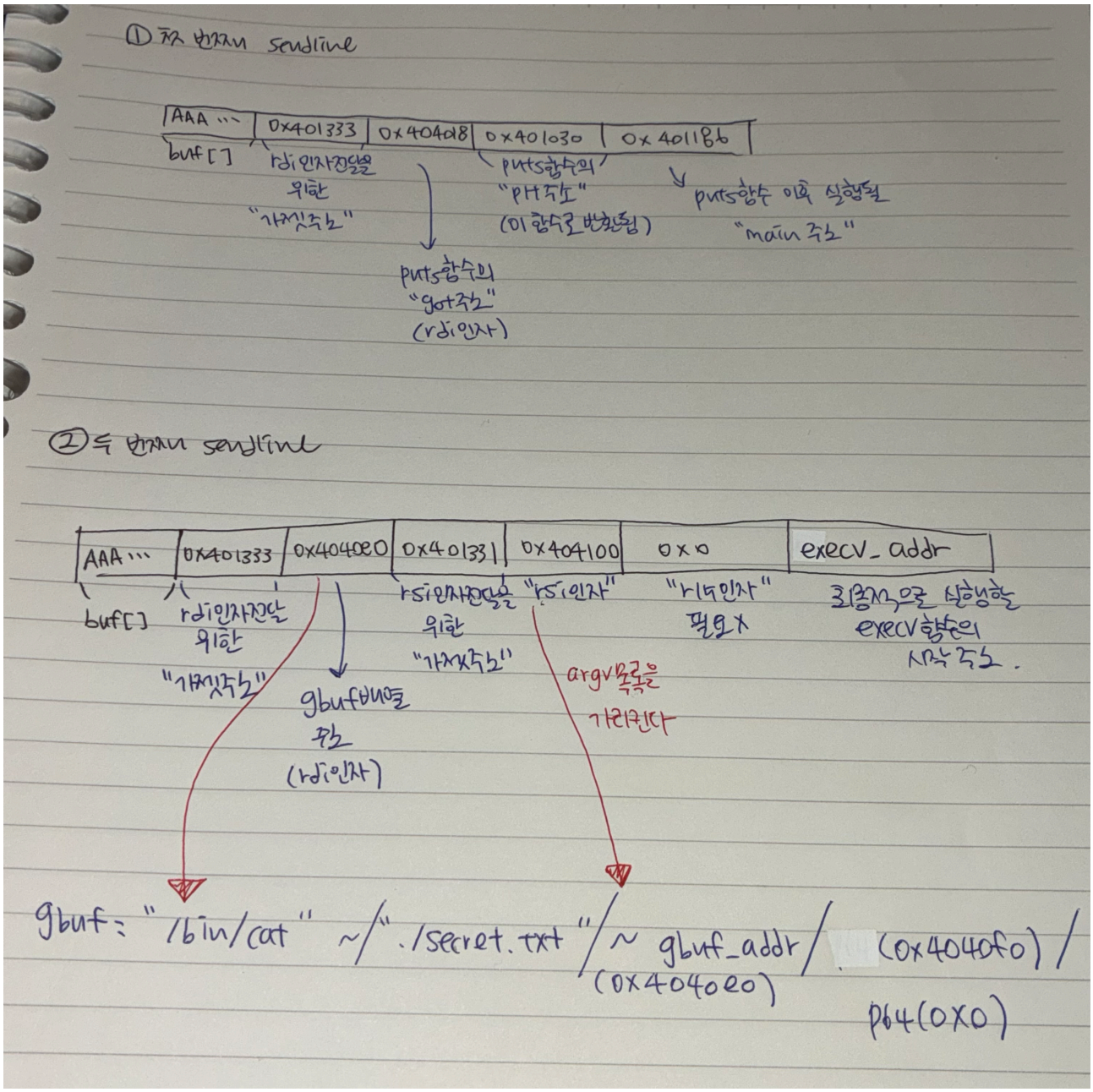
20231508 강유영

3-2.



(1) 첫 번째 sendline

- rdi인자에 puts함수의 got주소를 저장한다.
- 이후 puts함수의 plt주소로 이동한다. 이 때 인자로 puts함수의 got주소가 전달된다.
- puts함수를 이용해 puts함수를 실제 주소를 얻어내고 다시 main함수로 리턴하여 돌아간다.

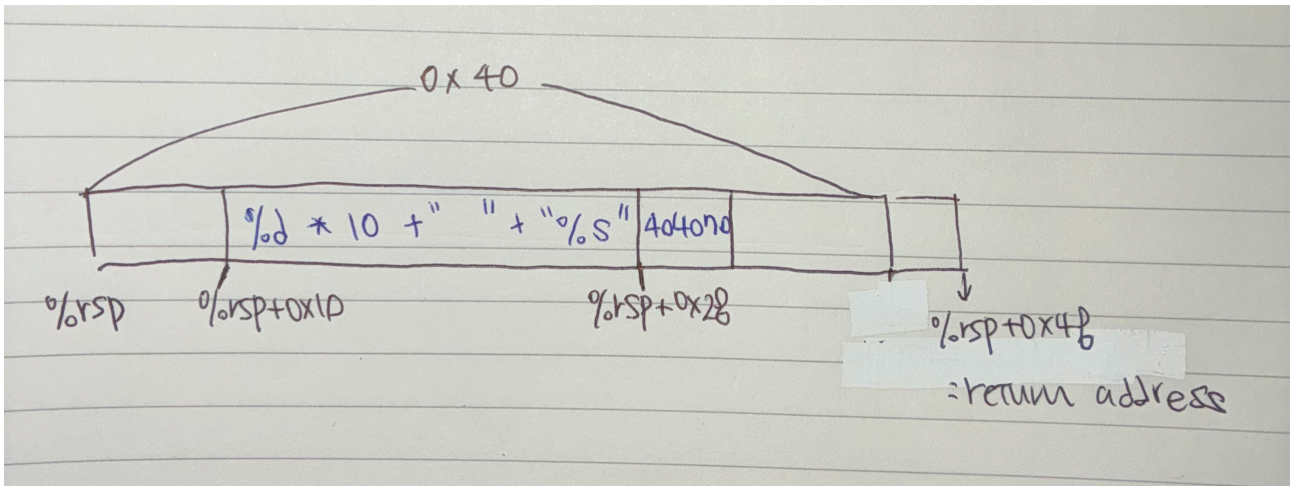
(2) gbuf 구성 (패딩은 생략)

- "/bin/cat" : argv[0]에 저장되는 값. 경로이다.
- “./secret.txt” : argv[1]에 저장되는 값.
- gbuf_addr : agrv[0]을 가리키는 포인터
- p64(0x4040f0) : argv[1]을 가리키는 포인터
- p64(0x0)) : argv[2]포인터. 널 값이다. Argv의 종료를 나타냄.

(3) 두 번째 sendline

- rdi인자에 gbuf배열의 시작 주소를 저장한다. (execv에 넣을 주소 인자이다)
- rsi인자에 0x404100(gbuf에 저장된 argv목록의 시작을 가리키는 주소)를 저장한다.
- r15인자는 더미이므로 아무 값이나 넣는다.
- 최종적으로 execv함수를 실행한다.
  - execv함수의 주소는 첫 번째 sendline에서 얻은 (puts함수의 주소 - puts함수 offset + execv함수 offset)로 구하였다.

3-3.



p.sendline(b"%d" * 10 + b" " + b"%s" + p64(0x404070))

(1) “%d” * 10

- 보통의 printf는 뒤에 같이 있는 인자를 읽어오는데, 위의 sendline을 보낼 경우 인자가 없다. 따라서 스택의 다른 위치를 읽어온다. (메인 스택)
- printf는 %d로 인자를 읽어올 때 4바이트씩 읽어온다. 즉, %d가 10개이므로 총 40바이트를 읽는다. (=0x28)

(2) “ “

- Printf는 4바이트씩 읽어오기 때문에 secret의 주소는 4의 배수에 있어야 한다. 이 공간은 payload를 조절하기 위해 추가한 빈 공간이다.

(3) “%s”

- printf는 %d로 40바이트를 읽었고, 이제 %s도 읽어야 한다.
- printf는 인자로 이미 40바이트 만큼을 읽었고 이제 %rsp + 0x28(40바이트) 위치를 읽어야 하는데, 해당 위치에는 secret의 주소가 저장되어 있다. (2번 항목의 공백을 통해 printf가 %s로 읽어야 하는 위치를 정확하게 조절했다.)

(4) p64(0x404070)

- open 함수가 0x404070으로 mov하기에 secret의 주소를 알 수 있었다.

(5) 정리

1. read함수로 미리 buf를 10개의 %d와 “ “, %s, secret 주소로 구성한다.
2. printf는 main스택의 데이터들을 %d로 출력하기에 10번의 출력 이후 %s출력 순서에서 출력 되는 위치에는 이미 read함수로 저장한 secret주소가 저장되어 있다.